

Mapeo GQM de bloques de la encuesta a requisitos normativos ISO 27001, ISO 27004 y NIS2

Esta tabla resume la relación entre:

- Los objetivos GQM principales (por familia de indicadores).
- Los bloques de preguntas de la encuesta.
- Las cláusulas de ISO/IEC 27001:2022, referencias de ISO/IEC 27004 y expectativas NIS2.

Objetivo GQM	Bloques encuesta relacionados	ISO/IEC 27001:2022 (cláusulas / Anexo A)	ISO/IEC 27004 / otros marcos	Comentario de alineamiento
G-MAD-1 (madurez SGSI)	B2 Gobernanza, B3 Metodología, B4	4, 5, 6, 9, 10; Anexo A global	ISO 27004 – modelo de medición; ISACA KPIs	Mide el desempeño global del SGSI y su mejora continua, como requiere la cláusula 9.1.
G-RISK-1 (riesgos)	B5 Gestión de riesgos	6.1, 6.2 (riesgos); Anexo A (controles)	ISO 27004 – métricas de riesgo; GQM aplicado a 27001 [web:43]	Cubre si el tratamiento de riesgos mantiene la exposición dentro del apetito aprobado.
G-TECH-1 (vulnerabilidades)	B6 Controles técnicos	Anexo A (controles técnicos, A.5–A.8)	TSM / métricas técnicas basadas en GQM [web:43]	Deriva métricas técnicas (parcheo, versiones, exposición) desde controles ISO 27001.
G-INC-1 (incidentes)	B7 Monitorización, SOC, incidentes	8.1–8.3; Anexo A (gestión de incidentes)	ENISA Threat Landscape; ISO 27004	Alinea indicadores de incidentes con requisitos de detección, respuesta y reporte.
G-AWARE-1 (concienciación)	B8 Concienciación y formación	7.2, 7.3; Anexo A (formación, cultura)	ISO 27004 – métricas organizativas	Mide la efectividad de acciones de concienciación y control del factor humano.
G-RES-1 (resiliencia)	B9 Continuidad y resiliencia	8.4; Anexo A (continuidad de negocio)	ENISA – resiliencia; guías BC/DR	Conecta pruebas y resultados de continuidad con objetivos RTO/RPO del SGSI.
G-SUP-1 (proveedores)	B10 Proveedores y terceros	Anexo A (relaciones con proveedores)	NIS2 – cadena de suministro	Evalúa la madurez en gestión de riesgo de terceros, clave en NIS2.

G-REG-1 (regulación)	B11 Regulación, B13 Reporte	6.1–6.3, 9.1 (cumplimiento)	NIS2; GDPR; ENISA guidance [web:46]	Asegura que las métricas internas soportan las obligaciones de reporte y diligencia.
G-GOV-1 (gobierno métricas)	B2 Gobernanza, B12 Automatización	5.1, 5.2, 7.5, 9.1	ISO 27004 – proceso de medición	Refleja la calidad del propio sistema de medición (automación, calidad de datos, gobierno).

Para un análisis más fino, puede extenderse este mapeo a nivel de pregunta individual usando las etiquetas de la encuesta (P2_1, P5_2, etc.) y asociándolas a objetivos GQM y controles específicos del Anexo A.